



Mestrado em Engenharia Informática
Cibersegurança e Administração de Sistemas

MarkDawn Phase 1

Relatório

Autores:

Abílio Correia 1212111
Eduardo Sampaio 1250511
Eduardo Vasconcelos 1250510
Diogo Melo 1250506

Desenvolvimento de Software Seguro

2025/2026

Índice

1	Introdução	7
2	Design do Sistema	8
2.1	Domain Driven Design	8
2.1.1	Deployment Diagram	10
2.2	Secure Architecture	11
2.2.1	Architecture Diagram	11
2.2.2	Cliente	13
2.2.3	API Layer	13
2.2.4	Application Layer	13
2.2.5	Data and External Services Layer	14
2.2.6	Logging and Monitoring Layer	14
2.3	Secure Design Principles	15
3	Requisitos	16
3.1	Requisitos Funcionais	16
3.2	Requisitos Não Funcionais	18
3.3	Requisitos de Segurança	19
3.4	Requisitos de Desenvolvimento Seguro	24
4	Use Cases	27
4.1	Diagramas de Casos de Uso	31
4.1.1	Gestão de Workspaces	31
4.1.2	Gestão de Documentos	32

5	Abuse Cases	33
5.1	Abuse Case 1 - Bypass de autenticação	33
5.2	Abuse Case 2 - Escalada de privilégios	33
5.3	AC3 - Acesso não autorizado a workspaces e documentos	34
5.4	AC4 - Path Traversal no sistema de ficheiros	34
5.5	AC5 - Cross-Site Scripting via Markdown	35
5.6	AC6 - Eliminação indevida de documentos	36
5.7	AC7 - Exportação indevida de documentos	36
5.8	AC8 - Brute force	37
5.9	AC9 - Falta de logging	37
5.10	AC10 - Manipulação de conteúdo na exportação	38
6	Análise de Ameaças e Estratégias de Mitigação (STRIDE)	39
7	Risk Assessment	41
7.1	Metodologia Utilizada no Risk Assessment	41
7.1.1	Escala de Probabilidade	41
7.1.2	Escala de Impacto	41
7.1.3	Matriz de Risco	42
7.2	Avaliação de Risco	42
8	Plano de Testes	44
9	Conclusão	46

Índice de imagens

1	Sub-dominios (DDD)	8
2	Agregados (DDD)	9
3	Deployment Diagram MarkDawn	10
4	Arquitetura segura do sistema	12
5	Diagrama de casos de uso — Gestão de Workspaces	31
6	Diagrama de casos de uso — Gestão de Documentos	32
7	Data Flow Diagram com análise de ameaças	39

Índice de tabelas

1	Formato de descrição de requisitos	16
2	Descrições de prioridades de requisitos	16
3	RF1 - Registo de utilizadores	16
4	RF2 - Autenticação de utilizadores	16
5	RF3 - Criação de workspaces	17
6	RF4 - Gestão de documentos Markdown	17
7	RF5 - Controlo de acessos por roles	17
8	RF6 - Exportação de documentos	17
9	RF7 - Gestão de utilizadores em workspaces	17
10	RNF1 - Performance	18
11	RNF2 - Disponibilidade	18
12	RNF3 - Escalabilidade	18
13	RNF4 - Logging e auditoria	18
14	RS1 - Password Hashing Seguro	19
15	RS2 - Política de passwords	19
16	RS3 - Autenticação com JWT	19
17	RS4 - Controlo de Acessos	20
18	RS5 - Validação de Inputs	20
19	RS6 - Sanitização de Markdown	20
20	RS7 - Segurança no sistema de ficheiros	20
21	RS8 - Proteção contra Brute Force	21
22	RS9 - Logging de segurança	21
23	RS10 - Proteção contra IDOR	21

24	RS11 - Validação de ownership de ficheiros	21
25	RS12 - Exportação segura de documentos	22
26	RS13 - Validação de payloads da API	22
27	RS14 - Integridade dos logs	22
28	RS15 - Gestão de sessões e revogação de tokens	22
29	RS16 - Proteção contra abuso da API (Rate Limiting)	23
30	RS17 - Headers de segurança HTTP	23
31	RS18 - Comunicações seguras (HTTPS)	23
32	RS19 - Proteção de dados em repouso	23
33	RDSS1 - Secure Coding Standards	24
34	RDSS2 - Security by design	24
35	RDSS3 - Gestão de segredos	24
36	RDSS4 - Security testing	25
37	RDSS5 - Dependency management	25
38	RDSS6 - Logging seguro	25
39	RDSS7 - Implementação segura de controlo de acessos	26
40	RDSS8 - Configuração segura	26
41	UC1 - Criar workspace	27
42	UC2 - Adicionar membro	27
43	UC3 - Remover membro	28
44	UC4 - Alterar role	28
45	UC5 - Criar documento	28
46	UC6 - Editar documento	29
47	UC7 - Visualizar documento	29

48	UC8 - Eliminar documento	29
49	UC9 - Exportar documento	30
50	Tabela de Ameaças STRIDE e Mitigações	40
51	Níveis de probabilidade de ocorrência	41
52	Níveis de impacto	41
53	Matriz de avaliação de risco baseada em probabilidade e impacto	42
54	Matriz de ameaças e avaliação de risco	42

1 Introdução

O desenvolvimento de aplicações web modernas exige uma abordagem que vá além da implementação de funcionalidades, incorporando mecanismos que garantam a segurança, fiabilidade e integridade dos sistemas. Com o aumento da complexidade das aplicações e da sofisticação dos ataques, torna-se essencial integrar práticas de segurança desde as fases iniciais do desenvolvimento.

Este projeto tem como objetivo o desenvolvimento de uma aplicação para gestão de workspaces e documentos. Para além da componente funcional, o projeto centra-se na identificação, análise e mitigação de riscos de segurança associados ao sistema.

Numa primeira fase, são definidos os requisitos do sistema, incluindo requisitos funcionais, não funcionais e de segurança. De seguida, são modelados os principais fluxos de interação através de diagramas de casos de uso e Data Flow Diagrams, que servem de base para a análise de ameaças.

A identificação de ameaças é realizada com recurso à metodologia STRIDE, permitindo classificar e estruturar os riscos associados aos diferentes componentes do sistema. Posteriormente, é conduzido um processo de avaliação de risco, no qual cada ameaça é analisada em termos de probabilidade e impacto.

Com base nesta análise, são propostas estratégias de mitigação e definida uma arquitetura segura que integra mecanismos de proteção adequados. Por fim, é apresentado um plano de testes que assegura a validação dos requisitos e das medidas de segurança implementadas.

Este relatório demonstra a aplicação de princípios de desenvolvimento seguro, evidenciando a importância de uma abordagem sistemática à segurança no ciclo de vida do software.

2 Design do Sistema

2.1 Domain Driven Design

Para o desenho e modelação do sistema MarkDawn, foi adotada a abordagem Domain-Driven Design.

Identificação dos Sub-domínios

A primeira etapa do processo consistiu na decomposição do domínio do sistema em subdomínios. Esta decomposição permite isolar responsabilidades e facilitar a evolução independente de cada área do sistema. Foram identificados três sub-domínios principais:

Identidade e Acesso — responsável por toda a lógica de autenticação de utilizadores e gestão de credenciais.

Gestão de Workspace — responsável pela criação e administração de espaços de trabalho colaborativos, bem como pela gestão dos seus membros e respetivas permissões. Cada workspace corresponde a uma estrutura de diretórios no sistema de ficheiros do servidor.

Gestão de Documentos — responsável pela gestão completa dos documentos Markdown, incluindo a sua criação, edição e organização. Este sub-domínio opera sempre no contexto de um workspace.

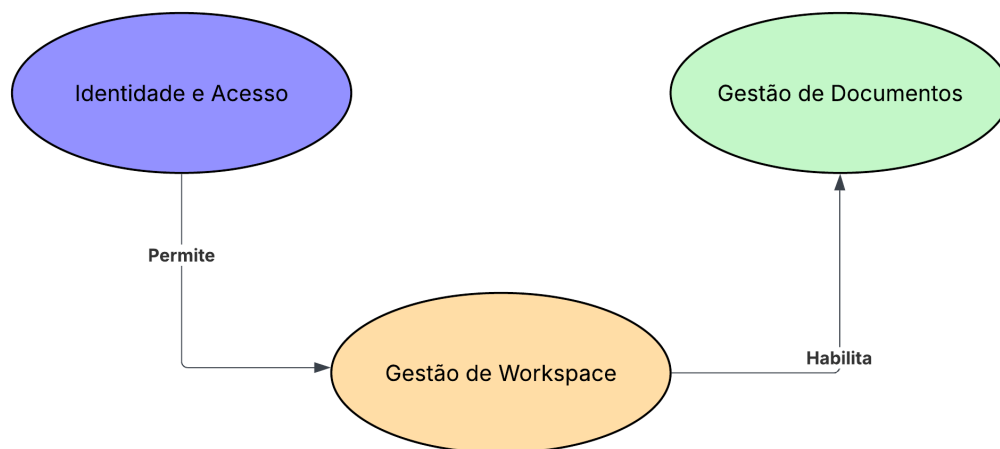


Figura 1: Sub-dominios (DDD)

Definição dos Agregados

Para cada sub-domínio foram definidos os respectivos agregados, seguindo o princípio de DDD de encapsulamento. Cada agregado é acessado exclusivamente através da sua aggregate root.

Identidade e Acesso

O agregado central deste sub-domínio é **User**, que funciona como aggregate root e representa um utilizador registado no sistema. Os seus value objects são **Email** e **HashedPassword**.

Gestão de Workspace

O agregado **Workspace** é a aggregate root deste sub-domínio e representa um espaço de trabalho, podendo ser individual ou partilhado entre vários utilizadores. Contém a entidade **Member** que representa a associação entre um utilizador e o workspace através de uma referência ao id único do utilizador (*user_id*). O role de cada membro é modelado como o value object **Role**, com os valores possíveis de Admin, Editor e Viewer. O sistema permite que ao mesmo utilizador sejam atribuídos roles distintos em workspaces diferentes. Complementam este agregado os value objects **WorkspaceName**, que valida o nome do espaço de trabalho, e **FolderPath**, que regista o caminho do diretório correspondente no sistema de ficheiros do servidor.

Gestão de Documentos

O agregado **Document** é a aggregate root deste sub-domínio e representa um documento Markdown. É composto pelos value objects **DocumentTitle**, que encapsula o título do documento, **FilePath**, que representa o caminho do ficheiro '.md' no sistema de ficheiros, e **MarkdownContent**, que encapsula o conteúdo textual do documento.

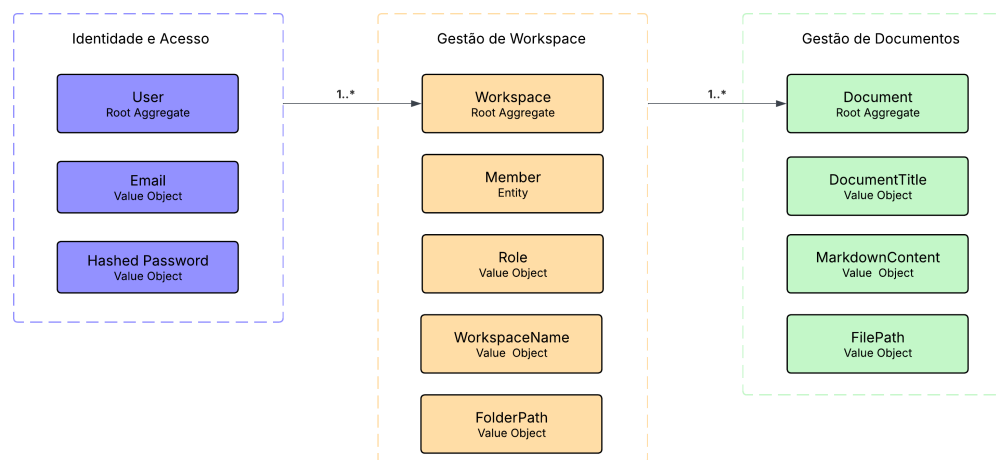


Figura 2: Agregados (DDD)

2.1.1 Deployment Diagram

O diagrama de deployment que se segue representa a distribuição física dos componentes do sistema e as comunicações estabelecidas entre eles.

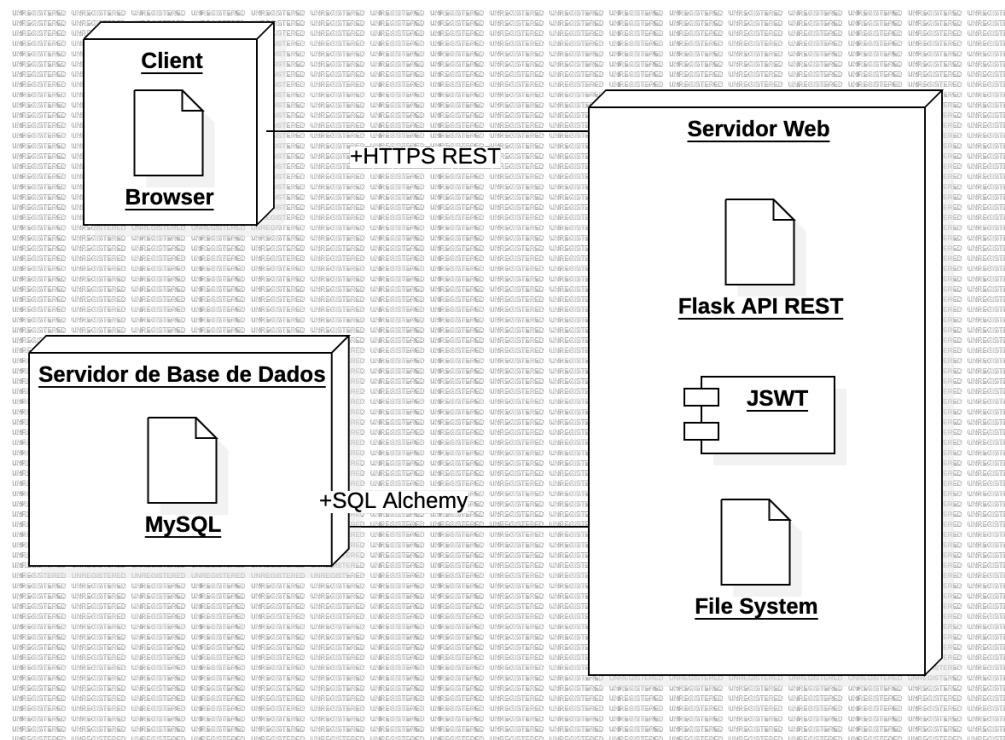


Figura 3: Deployment Diagram MarkDown

Client O nó cliente representa qualquer dispositivo a partir do qual o utilizador interage com o sistema. Toda a comunicação entre o cliente e o servidor é realizada sobre HTTPS, garantindo a confidencialidade e integridade dos dados em trânsito.

Web Server

O nó servidor web aloja a aplicação backend desenvolvida em **Python**, com recurso ao framework **Flask** para o desenvolvimento de uma interface REST API. A autenticação e autorização são geridas através de **JSON Web Tokens (JWT)**, validados em cada pedido antes de qualquer operação ser executada. A comunicação com a base de dados é realizada através de **SQLAlchemy**. O servidor é também responsável pela execução de operações sobre o sistema de ficheiros do sistema operativo, nomeadamente a criação de diretórios por workspace, a leitura e escrita de ficheiros .md correspondentes aos documentos, e a geração de ficheiros de log das operações realizadas.

Database Server

O nó de base de dados aloja uma instância **MySQL**, responsável pela persistência dos dados do sistema, como utilizadores, workspaces, membros e metadados dos documentos. O acesso à base de dados é feito exclusivamente pelo backend através de **SQLAlchemy**. O conteúdo dos documentos Markdown não é persistido na base de dados, residindo exclusivamente no sistema de ficheiros do servidor.

2.2 Secure Architecture

2.2.1 Architecture Diagram

A arquitetura do sistema foi concebida com uma abordagem orientada à segurança, baseada na separação em camadas com responsabilidades bem definidas. Esta organização permite reduzir a superfície de ataque, facilitar a aplicação de controlos de segurança e melhorar a manutenção do sistema.

O sistema segue um modelo cliente-servidor, onde o utilizador interage com a aplicação através de um navegador web, comunicando com uma API central responsável por processar todos os pedidos.

A Figura 4 apresenta a arquitetura do sistema, evidenciando as diferentes camadas e os principais mecanismos de segurança implementados.

A comunicação entre o cliente e o sistema é realizada através de HTTPS, garantindo a confidencialidade e integridade dos dados em trânsito. Todos os pedidos passam obrigatoriamente pela camada de API, que atua como ponto único de entrada no sistema.

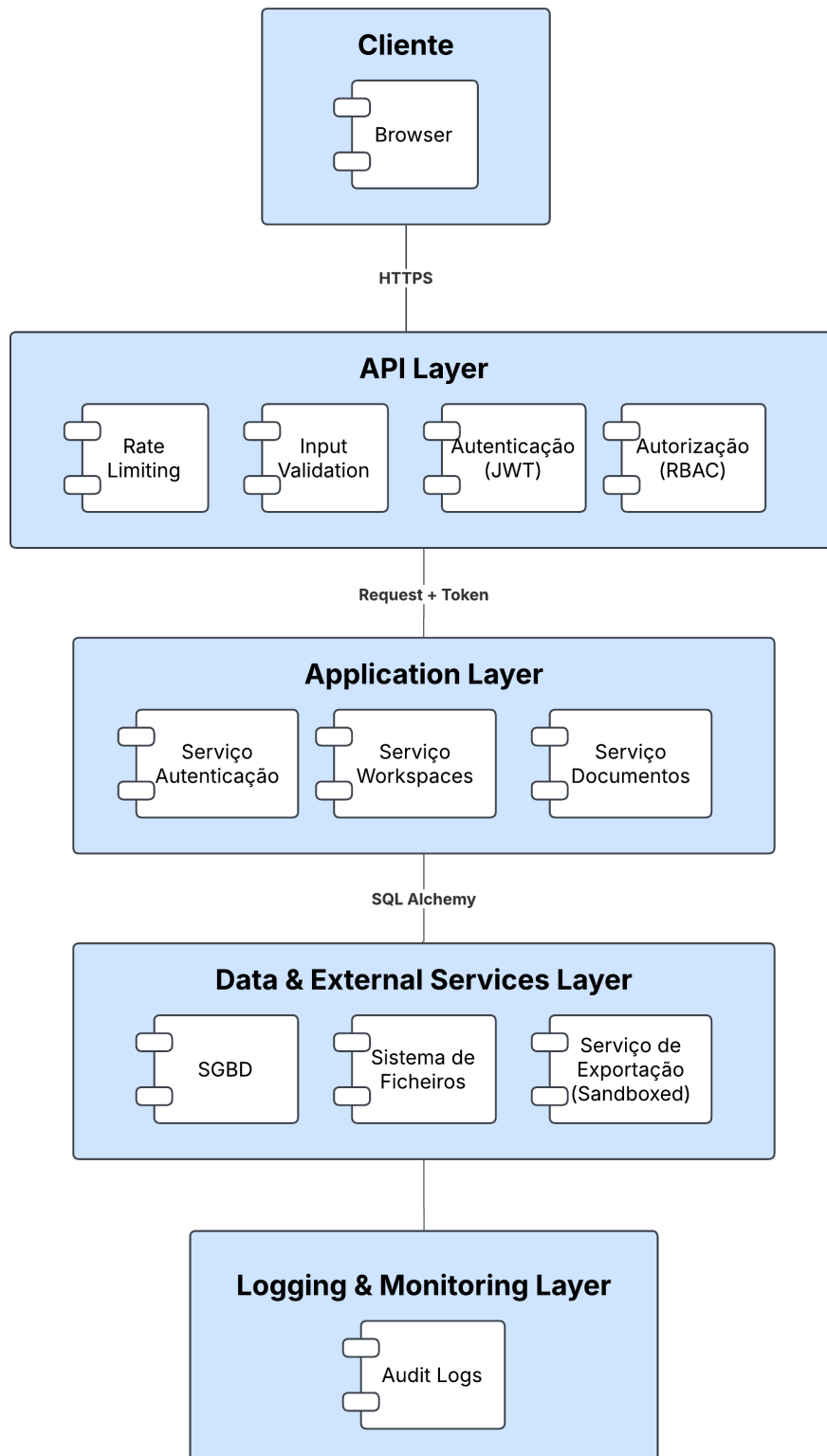


Figura 4: Arquitetura segura do sistema

2.2.2 Cliente

O cliente corresponde ao navegador web utilizado pelo utilizador para interagir com o sistema. Todas as operações são realizadas através de pedidos HTTP seguros, não existindo acesso direto aos componentes internos da aplicação.

2.2.3 API Layer

A camada de API é responsável por receber e processar todos os pedidos provenientes do cliente, sendo o principal ponto de controlo de segurança do sistema.

Esta camada integra vários mecanismos fundamentais:

- **Rate Limiting** – limita o número de pedidos por utilizador, mitigando ataques de brute force e abuso do sistema;
- **Validação de Input** – garante que todos os dados recebidos são validados e sanitizados, prevenindo vulnerabilidades como SQL Injection, Cross-Site Scripting e Path Traversal;
- **Autenticação (JWT)** – utiliza tokens para validar a identidade dos utilizadores após o login;
- **Autorização (RBAC)** – controla o acesso aos recursos com base em roles, assegurando que os utilizadores apenas acedem ao que lhes é permitido.

Após validação e verificação de permissões, os pedidos são encaminhados para a camada de aplicação.

2.2.4 Application Layer

A camada de aplicação contém a lógica de negócio do sistema, organizada em diferentes serviços responsáveis por funcionalidades específicas:

- **Serviço de Autenticação** – responsável pela gestão de utilizadores, incluindo registo, autenticação e emissão de tokens JWT. Este serviço valida credenciais, gere sessões e assegura que apenas utilizadores autenticados conseguem aceder ao sistema.
- **Serviço de Workspaces** – gere a criação, edição e eliminação de workspaces, bem como a associação de utilizadores aos mesmos. Este serviço aplica as regras de autorização, garantindo que apenas utilizadores com permissões adequadas podem aceder ou modificar um workspace.
- **Serviço de Documentos** – responsável pela gestão de documentos dentro dos workspaces, incluindo criação, edição, eliminação e exportação. Este serviço assegura a validação do conteúdo e o controlo de acessos, prevenindo acessos não autorizados e garantindo a integridade dos dados.

A separação da lógica de negócio em serviços distintos permite maior modularidade e facilita a aplicação de mecanismos de segurança específicos a cada componente, reduzindo o impacto de possíveis vulnerabilidades.

2.2.5 Data and External Services Layer

Esta camada inclui os componentes responsáveis pelo armazenamento e processamento de dados:

- **SGBD** – responsável pelo armazenamento de utilizadores, permissões e metadados do sistema;
- **Sistema de Ficheiros** – utilizado para armazenar os documentos;
- **Serviço de Exportação** – responsável pela conversão de documentos para outros formatos, sendo executado de forma controlada para reduzir riscos associados ao processamento de conteúdo.

O acesso a estes componentes é feito exclusivamente através da camada de aplicação, não sendo possível o acesso direto pelo cliente.

2.2.6 Logging and Monitoring Layer

A camada de logging e monitorização é responsável pelo registo de eventos relevantes do sistema, incluindo:

- Autenticações e tentativas de acesso;
- Operações sobre documentos;
- Ações críticas realizadas pelos utilizadores;

Estes registos permitem a deteção de comportamentos anómalos, suporte a auditorias e análise de incidentes de segurança.

2.3 Secure Design Principles

Nesta fase de desenho do sistema definem-se as práticas de segurança recomendadas pela OWASP que serão aplicadas ao longo do desenvolvimento do sistema.

Princípio do menor privilégio

Com o intuito de evitar permissões excessivas, será aplicado o princípio do menor privilégio em todo o sistema. Isto é, cada utilizador ou processo receberá apenas as permissões estritamente necessárias para executar as suas funções. Esta prática será aplicada ao nível dos utilizadores, através do sistema de roles (Admin, Editor, Viewer), ao nível da base de dados, através de um utilizador MySQL dedicado com permissões restritas às necessárias, e ao nível do sistema de ficheiros.

Autenticação e gestão de sessões segura

A autenticação será implementada com recurso a JSON Web Tokens (JWT) com um tempo de expiração curto, de forma a limitar a janela de exposição em caso de comprometimento de um token. As passwords serão sempre armazenadas hashed. Não serão aceites tokens expirados ou inválidos em nenhum endpoint da API, sendo o acesso negado por defeito em caso de falha de validação, seguindo o princípio de fail secure.

Validação e sanitização de inputs

Todos os dados recebidos pela API serão validados e sanitizados antes de serem processados, independentemente da sua origem. Esta prática visa prevenir ataques de injeção de código, nomeadamente SQL injection e path traversal. Os caminhos de ficheiros serão sempre construídos internamente pelo sistema, nunca a partir de input direto do utilizador.

Separação de responsabilidades

A arquitetura do sistema reflete uma separação de responsabilidades entre componentes. O processo de autenticação é independente da lógica de negócio, a base de dados não é acessível diretamente do exterior e o sistema de ficheiros é acedido exclusivamente através da camada de aplicação.

Defense in depth

A segurança do sistema não dependerá de um único mecanismo de proteção. Serão aplicadas múltiplas camadas de controlo como autenticação por JWT, autorização por role no contexto de cada workspace, validação de input na API e restrições ao nível do sistema de ficheiros e da base de dados.

Exposição mínima de informação

As respostas de erro da API não deverão expor informação interna do sistema. Em caso de erro, será devolvida apenas a informação necessária para o utilizador o compreender .

3 Requisitos

Os requisitos estão identificados através de um código único composto por um prefixo e um número sequencial. Os requisitos funcionais utilizam o prefixo **RF**, os requisitos não funcionais utilizam o prefixo **RNF** e os requisitos de segurança utilizam o prefixo **RS**.

Esta identificação permite uma referência clara e consistente aos requisitos ao longo do documento, facilitando a rastreabilidade dos requisitos.

Identificador	Sumário
Prioridade	Essencial / Condicional / Opcional
Descrição	Texto que descreva o requisito utilizando, se necessário, linguagem formal para que seja compreensível para o público-alvo.
Motivação	Principais razões que levaram à inclusão do requisito.

Tabela 1: Formato de descrição de requisitos

Grau	Significado
Essencial	O produto não pode ser aceite enquanto o requisito não for implementado da forma descrita.
Condicional	O requisito melhora o produto, mas não o torna inaceitável se não for implementado.
Opcional	Requisito desejável que poderá acrescentar algo ao sistema, mas não é necessário para o funcionamento base.

Tabela 2: Descrições de prioridades de requisitos

3.1 Requisitos Funcionais

RF1	Registo de utilizadores
Prioridade	Essencial
Descrição	O sistema deve permitir o registo de novos utilizadores através de email e password.
Motivação	Necessário para identificar e autenticar utilizadores.

Tabela 3: RF1 - Registo de utilizadores

RF2	Autenticação de utilizadores
Prioridade	Essencial
Descrição	O sistema deve permitir que utilizadores autenticados acessem ao sistema através de credenciais válidas.
Motivação	Garantir acesso controlado ao sistema.

Tabela 4: RF2 - Autenticação de utilizadores

RF3	Criação de workspaces
Prioridade	Essencial
Descrição	O sistema deve permitir a criação de workspaces para organização de documentos.
Motivação	Estruturar a informação e separar contextos de utilização.

Tabela 5: RF3 - Criação de workspaces

RF4	Gestão de documentos Markdown
Prioridade	Essencial
Descrição	O sistema deve permitir criar, editar, visualizar e eliminar documentos Markdown.
Motivação	Funcionalidade principal do sistema.

Tabela 6: RF4 - Gestão de documentos Markdown

RF5	Controlo de acessos por roles
Prioridade	Essencial
Descrição	O sistema deve restringir ações com base no papel do utilizador (Admin, Editor, Viewer).
Motivação	Garantir segurança e controlo de permissões.

Tabela 7: RF5 - Controlo de acessos por roles

RF6	Exportação de documentos
Prioridade	Condicional
Descrição	O sistema deve permitir exportar documentos para HTML ou PDF.
Motivação	Melhorar a utilidade do sistema.

Tabela 8: RF6 - Exportação de documentos

RF7	Gestão de utilizadores em workspaces
Prioridade	Essencial
Descrição	O sistema deve permitir gestão de utilizadores no workspace (adicionar, remover e alterar roles).
Motivação	Funcionamento contínuo e evolutivo de um workspace.

Tabela 9: RF7 - Gestão de utilizadores em workspaces

3.2 Requisitos Não Funcionais

RNF1	Performance
Prioridade	Condicional
Descrição	O sistema deve responder às requisições em tempo aceitável (menos de 2 segundos).
Motivação	Garantir boa experiência de utilização.

Tabela 10: RNF1 - Performance

RNF2	Disponibilidade
Prioridade	Condicional
Descrição	O sistema deve estar disponível a maior parte do tempo.
Motivação	Assegurar continuidade de serviço.

Tabela 11: RNF2 - Disponibilidade

RNF3	Escalabilidade
Prioridade	Opcional
Descrição	O sistema deve suportar crescimento de utilizadores e dados.
Motivação	Preparar o sistema para evolução futura.

Tabela 12: RNF3 - Escalabilidade

RNF4	Logging e Auditoria
Prioridade	Essencial
Descrição	O sistema deve registar eventos relevantes como login, criação e eliminação de workspaces e documentos.
Motivação	Permitir auditoria e deteção de problemas.

Tabela 13: RNF4 - Logging e auditoria

3.3 Requisitos de Segurança

RS1	Password Hashing Seguro
Prioridade	Essencial
Descrição	O sistema deve armazenar passwords utilizando algoritmos de hashing seguros (ex: bcrypt ou argon2).
Motivação	Proteger credenciais em caso de fuga de dados. Este requisito mitiga o abuse case 8, reduzindo o impacto de ataques de brute force e credential sniffing através da proteção das credenciais guardadas.

Tabela 14: RS1 - Password Hashing Seguro

RS2	Política de Passwords
Prioridade	Essencial
Descrição	O sistema deve impor requisitos mínimos de complexidade para passwords, incluindo comprimento mínimo e diversidade de caracteres.
Motivação	Reduzir o risco de utilização de passwords fracas e prevenir ataques de guessing. Este requisito mitiga o abuse case 8, prevenindo ataques de brute force e guessing através da imposição de passwords fortes.

Tabela 15: RS2 - Política de passwords

RS3	Autenticação com JWT
Prioridade	Essencial
Descrição	O sistema deve usar tokens JWT com tempo de expiração limitado para autenticação.
Motivação	Reduzir risco de uso indevido de sessões. Este requisito mitiga os abuse cases 1 e 8, prevenindo o bypass de autenticação e reutilização de tokens inválidos através do uso de JWT com expiração controlada.

Tabela 16: RS3 - Autenticação com JWT

RS4	Controlo de Acessos
Prioridade	Essencial
Descrição	O sistema deve implementar controlo de acessos no backend, garantindo que todas as operações sobre recursos são autorizadas com base na identidade e permissões do utilizador autenticado. A autorização deve ser verificada em todos os endpoints sensíveis, independentemente da validação no cliente.
Motivação	Garantir confidencialidade e integridade dos recursos. Este requisito mitiga os abuse cases 2 e 3, prevenindo escalada de privilégios e acessos não autorizados a recursos através de controlo de acessos no backend.

Tabela 17: RS4 - Controlo de Acessos

RS5	Validação de Inputs
Prioridade	Essencial
Descrição	O sistema deve validar todos os dados recebidos para prevenir ataques como SQL Injection.
Motivação	Proteger a base de dados contra manipulação de queries. Este requisito mitiga os abuse cases 4 e 10, prevenindo a exploração de inputs maliciosos que possam levar a execução de código ou manipulação de caminhos de ficheiros.

Tabela 18: RS5 - Validação de Inputs

RS6	Sanitização de Markdown
Prioridade	Essencial
Descrição	O sistema deve sanitizar e/ou renderizar de forma segura conteúdo Markdown antes de o apresentar.
Motivação	Evitar execução de scripts maliciosos (XSS). Este requisito mitiga o abuse case 5, prevenindo ataques de Cross-Site Scripting através da sanitização de conteúdo Markdown.

Tabela 19: RS6 - Sanitização de Markdown

RS7	Segurança no Sistema de Ficheiros
Prioridade	Essencial
Descrição	O sistema deve garantir que os acessos a ficheiros estão limitados ao diretório do workspace.
Motivação	Evitar ataques de path traversal e acesso a ficheiros do sistema. Este requisito mitiga o abuse case 4, prevenindo ataques de path traversal através da restrição de acesso a diretórios do workspace.

Tabela 20: RS7 - Segurança no sistema de ficheiros

RS8	Proteção contra Brute Force
Prioridade	Condicional
Descrição	O sistema deve limitar o número de tentativas de autenticação por utilizador ou IP.
Motivação	Prevenir ataques de força bruta. Este requisito mitiga o abuse case 8, prevenindo ataques de brute force através de limitação de tentativas de autenticação.

Tabela 21: RS8 - Proteção contra Brute Force

RS9	Logging de Segurança
Prioridade	Essencial
Descrição	O sistema deve registar eventos de segurança como falhas de login, acessos não autorizados e ações críticas.
Motivação	Permitir auditoria e deteção de comportamentos maliciosos. Este requisito mitiga o abuse case 9, permitindo a deteção e auditoria de ações maliciosas através do registo de eventos de segurança.

Tabela 22: RS9 - Logging de segurança

RS10	Proteção contra IDOR
Prioridade	Essencial
Descrição	O sistema deve garantir que qualquer acesso a recursos (workspaces, documentos e exportações) é validado com base na pertença do utilizador.
Motivação	Prevenir acesso não autorizado a recursos através da manipulação de identificadores. Este requisito mitiga o abuse case 3, prevenindo acesso não autorizado a recursos através da validação de ownership e permissões.

Tabela 23: RS10 - Proteção contra IDOR

RS11	Validação de Ownership de Ficheiros
Prioridade	Essencial
Descrição	O sistema deve garantir que todas as operações sobre ficheiros são validadas no backend com base no ownership do workspace.
Motivação	Evitar manipulação indevida de ficheiros entre workspaces. Este requisito mitiga os abuse cases 3 e 6, garantindo que apenas o proprietário do workspace pode aceder ou modificar ficheiros.

Tabela 24: RS11 - Validação de ownership de ficheiros

RS12	Exportação Segura de Documentos
Prioridade	Essencial
Descrição	O sistema deve garantir que apenas utilizadores com permissões válidas podem exportar documentos e que o conteúdo exportado não contém código executável.
Motivação	Prevenir exfiltração de dados e execução de código malicioso em ficheiros exportados. Este requisito mitiga os abuse cases 7 e 10, prevenindo exfiltração de dados e execução de conteúdo malicioso durante a exportação.

Tabela 25: RS12 - Exportação segura de documentos

RS13	Validação de Payloads da API
Prioridade	Essencial
Descrição	O sistema deve validar e rejeitar pedidos com payloads inválidos, inesperados ou malformados em todos os endpoints da API.
Motivação	Prevenir exploração de vulnerabilidades através de inputs manipulados. Este requisito mitiga os abuse cases 10 e 4, prevenindo exploração de payloads malformados ou maliciosos na API.

Tabela 26: RS13 - Validação de payloads da API

RS14	Integridade dos Logs
Prioridade	Essencial
Descrição	O sistema deve garantir que os logs de auditoria não podem ser alterados ou eliminados por utilizadores não autorizados. Este requisito mitiga o abuse case 9, garantindo que os registos de auditoria não podem ser manipulados ou eliminados.
Motivação	Garantir integridade dos registos de auditoria.

Tabela 27: RS14 - Integridade dos logs

RS15	Gestão de Sessões e Revogação de Tokens
Prioridade	Essencial
Descrição	O sistema deve garantir mecanismos de expiração e/ou invalidação de tokens JWT em caso de logout ou comprometimento da sessão, sempre que possível através de expiração curta ou blacklist de tokens.
Motivação	Prevenir reutilização de tokens comprometidos e melhorar a segurança das sessões. Este requisito mitiga os abuse cases 1 e 8, reduzindo o risco de reutilização de tokens comprometidos e sessões inválidas.

Tabela 28: RS15 - Gestão de sessões e revogação de tokens

RS16	Proteção contra Abuso da API (Rate Limiting)
Prioridade	Condicional
Descrição	O sistema deve implementar limitação de taxa nos endpoints críticos da API, como autenticação e operações sensíveis.
Motivação	Prevenir abuso automatizado da API e reduzir risco de ataques como brute force e scraping. Este requisito mitiga os abuse cases 8 e 1, prevenindo ataques automatizados como brute force e abuso de autenticação.

Tabela 29: RS16 - Proteção contra abuso da API (Rate Limiting)

RS17	Headers de Segurança HTTP
Prioridade	Condicional
Descrição	O sistema deve configurar headers de segurança HTTP, como Content-Security-Policy e X-Content-Type-Options.
Motivação	Mitigar ataques no browser, como XSS e content sniffing. Este requisito mitiga o abuse case 5, reduzindo a superfície de ataque para XSS e ataques baseados no browser.

Tabela 30: RS17 - Headers de segurança HTTP

RS18	Comunicações Seguras
Prioridade	Essencial
Descrição	O sistema deve utilizar HTTPS para todas as comunicações entre cliente e servidor. Em ambiente de desenvolvimento poderá ser utilizado um certificado self-signed, enquanto em produção devem ser utilizados certificados emitidos por uma autoridade certificadora confiável.
Motivação	Proteger dados em trânsito contra intercepção e garantir a autenticidade do servidor. Este requisito mitiga os abuse cases 1 e 7, protegendo a comunicação contra intercepção e ataques man-in-the-middle.

Tabela 31: RS18 - Comunicações seguras (HTTPS)

RS19	Proteção de Dados em Repouso
Prioridade	Essencial
Descrição	O sistema deve armazenar dados sensíveis de forma segura, podendo incluir encriptação ao nível da base de dados. Este requisito mitiga os abuse cases 7 e 9, protegendo dados sensíveis armazenados contra exfiltração e exposição.
Motivação	Reduzir o impacto de uma possível fuga de dados e proteger informação confidencial.

Tabela 32: RS19 - Proteção de dados em repouso

3.4 Requisitos de Desenvolvimento Seguro

RDSS1	Secure Coding Standards (OWASP Compliance)
Prioridade	Essencial
Descrição	O desenvolvimento da aplicação deve seguir as recomendações do OWASP Secure Coding Practices, incluindo validação de inputs, uso de queries parametrizadas, e proibição de credenciais hardcoded no código-fonte.
Motivação	Mitigar vulnerabilidades conhecidas como SQL Injection, XSS e exposição de segredos. Baseado em boas práticas OWASP e ASVS. Este requisito mitiga os abuse cases 4, 5 e 10, prevenindo vulnerabilidades comuns como XSS, path traversal e execução de código malicioso através de boas práticas OWASP.

Tabela 33: RDSS1 - Secure Coding Standards

RDSS2	Security by Design e Threat Modeling
Prioridade	Essencial
Descrição	A segurança deve ser considerada desde a fase de análise e desenho do sistema. Devem ser identificadas ameaças através de threat modeling e os requisitos de segurança devem derivar dessas ameaças.
Motivação	Garantir que a segurança é integrada no ciclo de desenvolvimento e não adicionada posteriormente. Este requisito garante que os requisitos de segurança são derivados de abuse cases identificados.

Tabela 34: RDSS2 - Security by design

RDSS3	Gestão Segura de Segredos
Prioridade	Essencial
Descrição	Credenciais, chaves API e segredos não podem ser armazenados no código-fonte. Devem ser geridos através de variáveis de ambiente ou serviços de secret management.
Motivação	Prevenir exposição de credenciais em repositórios ou builds. Este requisito mitiga os abuse cases 1 e 8, prevenindo exposição de credenciais e tokens sensíveis.

Tabela 35: RDSS3 - Gestão de segredos

RDSS4	Security Testing no Ciclo de Desenvolvimento
Prioridade	Essencial
Descrição	Devem ser realizadas análises de segurança durante o desenvolvimento, incluindo SAST (Static Application Security Testing) e DAST (Dynamic Application Security Testing), bem como testes baseados em abuse cases.
Motivação	Detetar vulnerabilidades cedo no ciclo de desenvolvimento. Este requisito mitiga todos os abuse cases identificados, através de testes de segurança automatizados e baseados em cenários de abuso.

Tabela 36: RDSS4 - Security testing

RDSS5	Gestão Segura de Dependências
Prioridade	Essencial
Descrição	Todas as dependências externas devem ser verificadas regularmente quanto a vulnerabilidades conhecidas e atualizadas para versões seguras.
Motivação	Reduzir risco de supply chain attacks e vulnerabilidades em bibliotecas externas. Este requisito mitiga os abuse cases 5 e 10, reduzindo vulnerabilidades introduzidas por bibliotecas externas.

Tabela 37: RDSS5 - Dependency management

RDSS6	Logging e Monitorização Segura
Prioridade	Essencial
Descrição	A aplicação deve implementar logging estruturado de eventos relevantes e garantir que logs não expõem dados sensíveis como passwords ou tokens.
Motivação	Permitir deteção de incidentes e suporte a auditoria sem comprometer dados sensíveis. Este requisito mitiga os abuse cases 9 e 1, garantindo que eventos críticos são registados sem exposição de dados sensíveis.

Tabela 38: RDSS6 - Logging seguro

RDSS7	Implementação Segura de Controlo de Acessos
Prioridade	Essencial
Descrição	A implementação do sistema deve garantir que toda a lógica de controlo de acessos é executada exclusivamente no backend, não sendo possível ao cliente influenciar permissões, roles ou ownership de recursos. Devem ser aplicados princípios de least privilege e RBAC na implementação, assegurando que cada endpoint valida explicitamente a autorização antes de executar qualquer operação.
Motivação	Evitar falhas de implementação que possam levar a escalada de privilégios ou bypass de controlo de acessos. Este requisito mitiga os abuse cases 2 e 3, prevenindo escalada de privilégios e acessos indevidos através de aplicação de RBAC e least privilege.

Tabela 39: RDSS7 - Implementação segura de controlo de acessos

RDSS8	Configuração Segura e Separação de Ambientes
Prioridade	Essencial
Descrição	O sistema deve ser configurado de forma segura, garantindo separação entre ambientes de desenvolvimento, teste e produção. Funcionalidades de debug devem ser desativadas em produção e configurações sensíveis devem ser geridas externamente.
Motivação	Reduzir risco de exposição de informação sensível e configurações inseguras em produção. Este requisito mitiga os abuse cases 9 e 1, reduzindo riscos de exposição de informação através de configurações inseguras entre ambientes.

Tabela 40: RDSS8 - Configuração segura

4 Use Cases

UC1	Criar workspace
Ator	Administrador
Descrição	Este caso de uso permite ao administrador criar um novo workspace no sistema, definindo um espaço isolado para organização de documentos e colaboração entre utilizadores. O sistema deve garantir que o workspace é corretamente inicializado e associado ao utilizador criador.
Impacto	A criação de workspaces permite estruturar a informação por diferentes contextos, facilitando a separação lógica de dados entre equipas ou projetos. Esta funcionalidade constitui a base da organização do sistema e permite suportar colaboração segura entre utilizadores.
Requisitos	RF3

Tabela 41: UC1 - Criar workspace

UC2	Adicionar membro
Ator	Administrador
Descrição	Este caso de uso permite ao administrador adicionar um utilizador a um workspace existente, atribuindo-lhe acesso aos respetivos recursos. O sistema deve validar a identidade do utilizador e garantir a correta atribuição de permissões.
Impacto	Esta funcionalidade permite a colaboração entre utilizadores dentro de um mesmo workspace, garantindo simultaneamente que apenas utilizadores autorizados têm acesso aos recursos. Contribui diretamente para o controlo de acessos e gestão de equipas.
Requisitos	RF7, RS4

Tabela 42: UC2 - Adicionar membro

UC3	Remover membro
Ator	Administrador
Descrição	Este caso de uso permite ao administrador remover um utilizador de um determinado workspace, revogando o seu acesso a documentos e recursos associados. O sistema deve garantir que apenas utilizadores autorizados podem executar esta operação.
Impacto	A remoção de membros permite gerir dinamicamente os acessos ao sistema, prevenindo acessos indevidos e protegendo informação sensível. Esta funcionalidade é essencial para manter a segurança e integridade dos dados.
Requisitos	RF7, RS4

Tabela 43: UC3 - Remover membro

UC4	Alterar role
Ator	Administrador
Descrição	Este caso de uso permite ao administrador alterar o role de um utilizador dentro de um workspace, definindo o seu nível de permissões. O sistema deve garantir que esta operação é realizada de forma controlada e segura.
Impacto	A alteração de roles permite ajustar dinamicamente os privilégios dos utilizadores, garantindo que cada utilizador possui apenas as permissões necessárias. Esta abordagem contribui para a aplicação do princípio do menor privilégio.
Requisitos	RF5, RS4

Tabela 44: UC4 - Alterar role

UC5	Criar documento
Ator	Editor, Admin
Descrição	Este caso de uso permite a criação de um documento em formato Markdown dentro de um workspace. O sistema deve garantir a persistência do documento e a sua associação ao workspace correspondente.
Impacto	A criação de documentos constitui uma funcionalidade central do sistema, permitindo aos utilizadores gerar conteúdo estruturado. Esta funcionalidade suporta a gestão de informação e a colaboração entre utilizadores.
Requisitos	RF4, RS7

Tabela 45: UC5 - Criar documento

UC6	Editar documento
Ator	Editor, Admin
Descrição	Este caso de uso permite modificar o conteúdo de um documento existente, garantindo que apenas utilizadores autorizados podem realizar alterações. O sistema deve validar os dados introduzidos pelo utilizador.
Impacto	A edição de documentos permite manter a informação atualizada e consistente. A validação de inputs reduz o risco de introdução de conteúdo inválido ou malicioso, contribuindo para a integridade do sistema.
Requisitos	RF4, RS5, RS11

Tabela 46: UC6 - Editar documento

UC7	Visualizar documento
Ator	Viewer, Editor, Admin
Descrição	Este caso de uso permite a visualização de documentos existentes no sistema. O sistema deve garantir que o conteúdo é apresentado de forma segura.
Impacto	Esta funcionalidade permite o acesso à informação de forma controlada, garantindo proteção contra a execução de código malicioso, como ataques XSS, e assegurando a segurança dos utilizadores.
Requisitos	RF4, RS6

Tabela 47: UC7 - Visualizar documento

UC8	Eliminar documento
Ator	Editor, Admin
Descrição	Este caso de uso permite eliminar documentos existentes no sistema. O sistema deve validar permissões antes da execução da operação.
Impacto	A eliminação de documentos permite gerir o ciclo de vida da informação, removendo conteúdos desnecessários ou obsoletos. No entanto, esta operação requer um controlo rigoroso para evitar eliminações indevidas.
Requisitos	RF4, RS4, RS11

Tabela 48: UC8 - Eliminar documento

UC9	Exportar documento
Ator	Editor, Admin
Descrição	Este caso de uso permite exportar documentos para formatos externos, como HTML ou PDF. O sistema deve garantir a segurança do conteúdo exportado.
Impacto	A exportação de documentos permite a partilha de informação fora do sistema, aumentando a sua utilidade e flexibilidade. No entanto, exige controlo de acessos e validação do conteúdo para evitar exfiltração de dados ou execução de código malicioso.
Requisitos	RF6, RS12, RS10

Tabela 49: UC9 - Exportar documento

4.1 Diagramas de Casos de Uso

4.1.1 Gestão de Workspaces

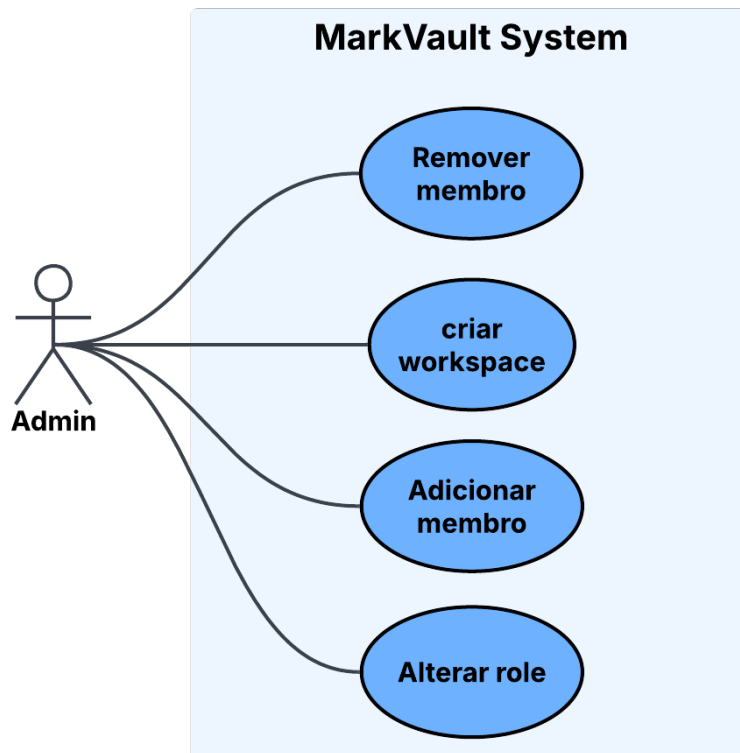


Figura 5: Diagrama de casos de uso — Gestão de Workspaces

O diagrama de gestão de workspaces representa as funcionalidades associadas à administração e organização dos espaços de trabalho no sistema MarkVault. Neste contexto, o único ator envolvido é o **Administrador**, sendo responsável por todas as operações relacionadas com a gestão de utilizadores e estrutura do workspace.

As operações disponíveis incluem a criação de novos workspaces, a adição e remoção de membros, bem como a alteração dos respetivos roles. Estas funcionalidades permitem ao administrador controlar o acesso aos recursos do sistema, garantindo que apenas utilizadores autorizados participam em cada workspace.

Este conjunto de funcionalidades assegura uma gestão eficiente das equipas e contribui diretamente para a aplicação de mecanismos de controlo de acessos e do princípio do menor privilégio, fundamentais para a segurança do sistema.

4.1.2 Gestão de Documentos

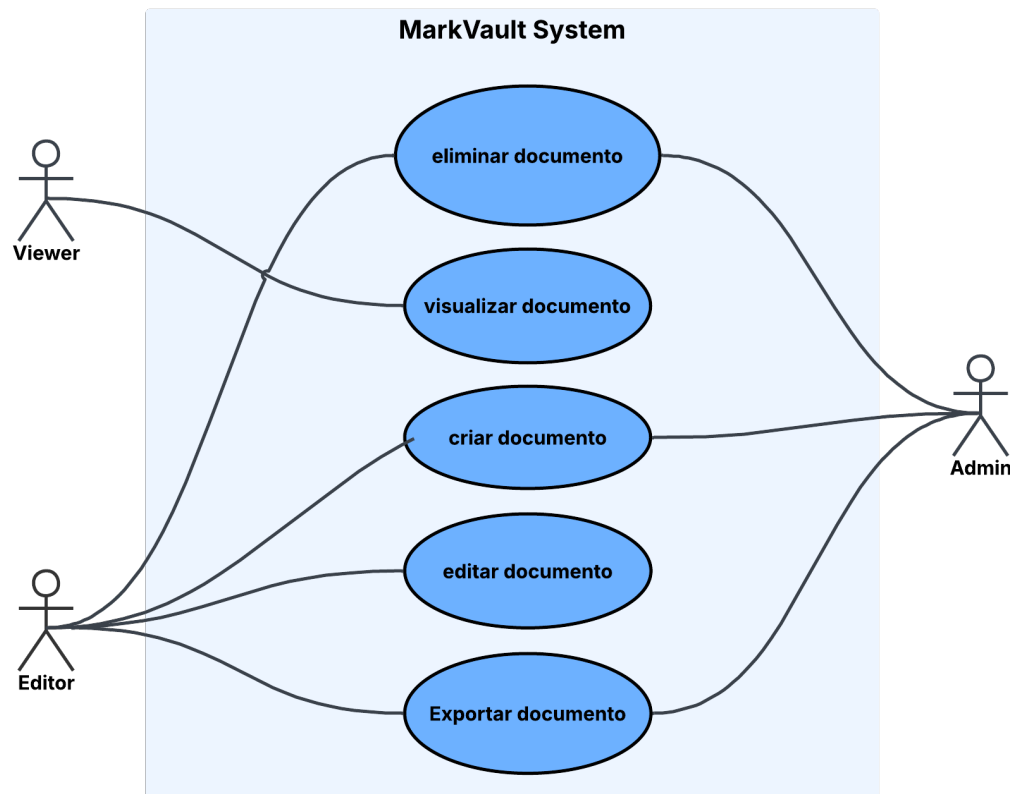


Figura 6: Diagrama de casos de uso — Gestão de Documentos

O diagrama de gestão de documentos representa as funcionalidades centrais do sistema relacionadas com a criação, manipulação e consulta de documentos. Neste contexto, existem três tipos de atores: **Viewer**, **Editor** e **Administrador**, cada um com diferentes níveis de permissões.

O **Viewer** possui permissões limitadas, podendo apenas visualizar documentos, garantindo acesso controlado à informação. O **Editor** dispõe de permissões adicionais, podendo criar, editar, eliminar e exportar documentos, sendo responsável pela gestão ativa do conteúdo. Por sua vez, o **Administrador** possui acesso total, podendo executar todas as operações disponíveis no sistema.

Este modelo baseado em roles permite implementar um controlo de acessos robusto, assegurando a separação de responsabilidades entre utilizadores e contribuindo para a integridade, confidencialidade e segurança da informação gerida pelo sistema.

5 Abuse Cases

5.1 Abuse Case 1 - Bypass de autenticação

Um atacante tenta contornar o mecanismo de autenticação do sistema, com o objetivo de aceder a funcionalidades protegidas sem possuir credenciais válidas. O ataque poderá ocorrer através de acesso direto a endpoints que não estejam corretamente protegidos ou através da reutilização de tokens JWT expirados, comprometidos ou inválidos. Caso o sistema não consiga validar corretamente a autenticidade e a validade do token JWT, o atacante pode obter acesso indevido à aplicação.

Impacto:

- Acesso não autorizado ao sistema;
- Comprometimento das contas dos utilizadores;
- Possível acesso aos dados sensíveis.

Mitigação:

- Validação obrigatória de JWT em todos os endpoints protegidos;
- Verificação da assinatura e expiração de tokens JWT;
- Definição de tempos de expiração dos tokens JWT curtos;

5.2 Abuse Case 2 - Escalada de privilégios

Um utilizador com permissões limitadas, poderá tentar obter privilégios de admin através da manipulação de dados enviados para a API ou explorar falhas na validação de permissões. Este tipo de ataque pode envolver a alteração do campo de role em pedidos ou o acesso direto a endpoints destinados a administradores. Se não existir uma validação adequada no servidor, o utilizador poderá adquirir permissões elevadas.

Impacto:

- Controlo total do sistema;
- Criação e gestão indevida de workspaces;
- Alteração de permissões de outros utilizadores.

Mitigação:

- Gestão de roles exclusivamente no backend;
- Ignorar qualquer valor de role enviado pelo cliente;
- Verificação rigorosa de permissões em todos os endpoints administrativos;
- Aplicação do princípio do menor privilégio.

5.3 AC3 - Acesso não autorizado a workspaces e documentos

Um utilizador autenticado tenta aceder a workspaces ou documentos que não lhe pertencem, manipulando identificadores nos pedidos. Este tipo de ataque é típico de vulnerabilidades como *Insecure Direct Object References (IDOR)*, onde o sistema não valida corretamente a autorização antes de devolver os dados.

Impacto:

- Violação da confidencialidade;
- Exposição de documentos e dados internos;
- Acesso indevido a informação de outras equipas.

Mitigação:

- Verificação de pertença do utilizador ao Workspace em todas as operações;
- Validação de ownership antes de aceder a qualquer recurso;
- Implementação consistente de controlo de acessos;
- Utilização de identificadores não previsíveis.

5.4 AC4 - Path Traversal no sistema de ficheiros

Durante operações que envolvem o sistema de ficheiros, como criação, edição, eliminação ou exportação de documentos, um utilizador malicioso pode tentar explorar vulnerabilidades de path traversal. Isto é feito através da manipulação de caminhos de ficheiros, utilizando sequências de caracteres para escapar ao diretório permitido do Workspace e aceder a ficheiros do sistema ou de outros utilizadores.

Impacto:

- Acesso a ficheiros sensíveis do servidor;
- Modificação ou eliminação de dados fora do âmbito permitido;
- Compromisso da integridade do sistema de ficheiros.

Mitigação:

- Normalização e validação rigorosa de todos os caminhos de ficheiros;
- Restrição de acesso a diretórios específicos por Workspace;
- Bloqueio de sequências de navegação como “../”;
- Utilização de caminhos absolutos controlados pelo servidor.

5.5 AC5 - Cross-Site Scripting via Markdown

Um utilizador malicioso insere código HTML ou JavaScript dentro de um documento Markdown. Quando outro utilizador visualiza o documento, o código malicioso pode ser executado no navegador da vítima. Este tipo de ataque pode ser utilizado para roubar tokens de sessão ou executar ações em nome do utilizador.

Impacto:

- Roubo de tokens de autenticação;
- Execução de ações não autorizadas;
- Compromisso da sessão do utilizador.

Mitigação:

- Sanitização do conteúdo Markdown antes da renderização;
- Utilização de bibliotecas seguras para conversão Markdown → HTML;
- Aplicação de Content Security Policy;
- Restrição ou filtragem de HTML embebido.

5.6 AC6 - Eliminação indevida de documentos

Um utilizador pode tentar eliminar documentos que não lhe pertencem, manipulando identificadores de documentos ou explorando falhas no controlo de acessos. Se o sistema não validar corretamente as permissões do recurso, poderá permitir a eliminação indevida de dados.

Impacto:

- Perda de dados;
- Violação da integridade do sistema;

Mitigação:

- Verificação de ownership antes de permitir operações de eliminação;
- Implementação de controlo de acessos rigoroso;
- Registo de ações críticas em logs de auditoria.

5.7 AC7 - Exportação indevida de documentos

A funcionalidade de exportação pode ser abusada por utilizadores que tentem exportar documentos pertencentes a workspaces aos quais não têm acesso. Isto pode ser feito através da manipulação de parâmetros da requisição ou exploração de falhas na validação de permissões.

Impacto:

- Exfiltração de dados sensíveis;
- Violação de confidencialidade;
- Divulgação indevida de informação.

Mitigação:

- Verificação de permissões antes da exportação;
- Validação do acesso ao Workspace e ao documento;
- Registo das operações de exportação para auditoria;
- Limitação de acesso a ficheiros exportados.

5.8 AC8 - Brute force

Um atacante pode tentar autenticar-se no sistema testando combinações de email e password ou através de credenciais de outros serviços previamente comprometidas. Sem mecanismos de proteção, o sistema pode ser vulnerável a comprometimento de contas de utilizadores.

Impacto:

- Comprometimento de contas de utilizadores;
- Acesso indevido a documentos e workspaces;

Mitigação:

- Rate limiting no endpoint de login;
- Bloqueio temporário após várias tentativas falhadas;
- Passwords armazenadas com hashing forte;
- Monitorização de tentativas de autenticação suspeitas.

5.9 AC9 - Falta de logging

Um atacante pode explorar a ausência de mecanismos de logging para executar ações maliciosas sem deixar rastro, como eliminar documentos, alterar permissões ou exportar dados sensíveis.

Impacto:

- Dificuldade em detetar possíveis ataques;
- Impossibilidade de auditoria;
- Perda de rastreabilidade de ações críticas.

Mitigação:

- Logging de todas as operações críticas;
- Registo de utilizador, timestamp e ação;
- Proteção dos ficheiros de log contra alteração;
- Monitorização e análise de logs.

5.10 AC10 - Manipulação de conteúdo na exportação

Um utilizador pode explorar a funcionalidade de exploração de documentos para inserir conteúdo malicioso que é processado durante a conversão para outro formato. Dependendo da ferramenta utilizada para a conversão, isto pode levar à execução de código no servidor.

Impacto:

- Possível execução de código no lado do servidor;
- Comprometimento do sistema durante o processo de exportação;
- Inclusão de conteúdo malicioso em ficheiros exportados.

Mitigação:

- Utilização de ferramentas de conversão seguras;
- Execução de processos de exportação em ambiente isolado;
- Sanitização do conteúdo antes da conversão.

6 Análise de Ameaças e Estratégias de Mitigação (STRIDE)

O sistema MardkDawn baseia-se numa arquitetura cliente-servidor onde a única entidade externa ao *Trust Boundary* é o Utilizador, que interage com a aplicação através de um navegador web.

A comunicação é iniciada através de um processo de Autenticação, que valida as credenciais através de uma base de dados interna e devolve um Token de Acesso (JWT). Uma vez autenticado, todos os pedidos do utilizador são centralizados num ponto de entrada (Flask REST API), que coordena a lógica entre os diferentes módulos: **Gestor de Workspace** (controlo de permissões), **Gestor de Documentos** e o **Processador de Documentos** (conversão de Markdown para HTML). O armazenamento de dados é segregado entre uma base de dados relacional e um sistema de ficheiros.

O diagrama de fluxo de dados que se segue procura retratar o movimento de dados no sistema, entre stores, processos e atores. Esta representação permitiu ainda a análise de vulnerabilidades partindo da arquitetura.

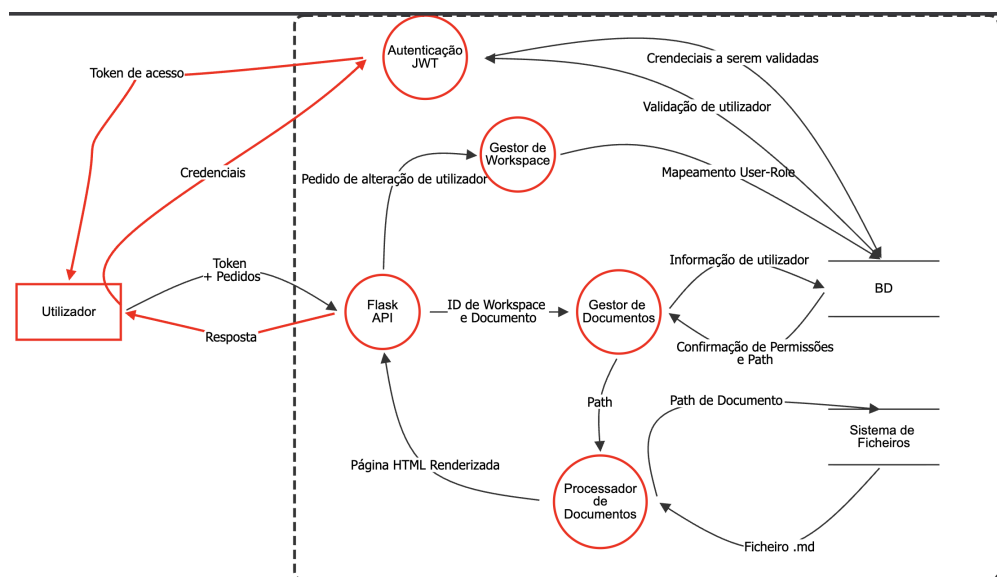


Figura 7: Data Flow Diagram com análise de ameaças

A tabela abaixo resume as principais ameaças identificadas no sistema, classificadas segundo a metodologia STRIDE, e as respectivas medidas de mitigação propostas.

Componente	Ameaça	Descrição	Mitigação Proposta
Utilizador	Spoofing (Critical)	Roubo de identidade ou interceção de credenciais.	Políticas de passwords fortes e uso obrigatório de HTTPS.
	Repudiation (high severity)	Incapacidade de rastrear ações críticas (ex: apagar docs).	Sistema de Logging detalhado (ID, Ação, Timestamp, IP).
Fluxos de Dados	Info Disclosure	Interceção (High Severity) do Token JWT durante a transmissão.	Encriptação via TLS/HTTPS e uso de Refresh Tokens curtos.
	Tampering (Critical)	Injeção de SQL ou Scripts.	Sanitização de inputs e uso de Prepared Statements.
Gestor de Documentos	Tampering (Medium severity)	Acesso a documentos não autorizados	Validação de permissões em relação ao documento no backend.
Processador MD	Tampering (Critical)	Injeção de scriptsem ficheiros Markdown.	Sanitização de HTML antes da renderização.
Gestor Workspace	Elevation of Privilege (Critical)	Alteração não autorizada de permissões ou roles.	RBAC rigoroso e validação de permissões de Admin no servidor.
Flask API	Denial of Service (High severity)	Sobrecarga do sistema com pedidos massivos ou ficheiros gigantes.	Implementação de Rate Limiting e quotas de tamanho de ficheiro.
	Elevation of Privilege (Critical)	Exploração de vulnerabilidades de API.	Segregação da Lógica de negócio.

Tabela 50: Tabela de Ameaças STRIDE e Mitigações

7 Risk Assessment

7.1 Metodologia Utilizada no Risk Assessment

Nesta secção é apresentada a metodologia de avaliação de risco utilizada para priorizar as ameaças de segurança identificadas.

Foi adotada uma abordagem qualitativa baseada na combinação de dois fatores principais: **Probabilidade** e **Impacto**. Esta abordagem permite identificar quais as ameaças que representam maior risco e que devem ser tratadas com prioridade.

Probabilidade Representa a possibilidade de uma ameaça ser explorada com sucesso.

Impacto Representa o dano potencial causado ao sistema, aos utilizadores ou dados caso a ameaça se concretize.

7.1.1 Escala de Probabilidade

Nível	Descrição
Baixa	Pouco provável de ocorrer, requer condições específicas ou conhecimentos avançados
Média	Possível de ocorrer em determinadas circunstâncias
Alta	Provável de ocorrer utilizando técnicas comuns de ataque

Tabela 51: Níveis de probabilidade de ocorrência

7.1.2 Escala de Impacto

Nível	Descrição
Baixo	Impacto reduzido, com pouca influência no funcionamento do sistema
Médio	Impacto moderado, afetando funcionalidades ou alguns dados
Alto	Impacto elevado, comprometendo a segurança, integridade ou disponibilidade

Tabela 52: Níveis de impacto

7.1.3 Matriz de Risco

Impacto Probabilidade	Baixo	Médio	Alto
Baixa	Baixo	Baixo	Médio
Média	Baixo	Médio	Alto
Alta	Médio	Alto	Crítico

Tabela 53: Matriz de avaliação de risco baseada em probabilidade e impacto

7.2 Avaliação de Risco

A tabela seguinte apresenta a avaliação de risco das principais ameaças identificadas.

Ameaça	Abuse Case Relacionado	Probabilidade	Impacto	Nível de Risco
Cross-Site Scripting via Markdown	AC5	Alta	Alto	Crítico
Acesso não autorizado	AC3	Alta	Alto	Crítico
Path Traversal	AC4	Média	Alto	Alto
SQL Injection	AC5	Média	Alto	Alto
Ataques de força bruta / Credential Stuffing	AC8	Alta	Médio	Alto
Escalada de privilégios	AC2	Média	Alto	Alto
Manipulação de ficheiros	AC6	Média	Alto	Alto
Exposição de informação sensível	AC6	Média	Médio	Médio
Falta de logging / repúdio	AC9	Média	Médio	Médio
Negação de serviço	AC9	Média	Médio	Médio
Conteúdo malicioso na exportação	AC10	Média	Alto	Alto

Tabela 54: Matriz de ameaças e avaliação de risco

A análise realizada demonstra que as ameaças mais críticas são o Cross-Site Scripting e o acesso não autorizado, uma vez que apresentam elevada probabilidade de exploração e impacto significativo na confidencialidade e integridade dos dados.

As ameaças associadas ao sistema de ficheiros, como o Path Traversal e a manipulação de ficheiros, também apresentam risco elevado, devido à dependência do sistema na gestão de documentos Markdown armazenados no sistema de ficheiros.

As ameaças relacionadas com autenticação, como ataques de força bruta, são consideradas de risco elevado devido à sua elevada probabilidade, apesar de o seu impacto poder ser mitigado com mecanismos adequados.

Por outro lado, ameaças como a exposição de informação sensível e a falta de logging apresentam risco médio, sendo importantes sobretudo no contexto de auditoria e resposta a incidentes.

8 Plano de Testes

Plano de teste seguro é um documento estruturado que define o âmbito, a estratégia, recursos e cronograma para validar a segurança da aplicação. Tem o objetivo de identificar vulnerabilidades, falhas de lógica de segurança e riscos de conformidade antes da aplicação estar em produção.

Âmbito

O âmbito a ser testado no Markdown é o seguinte:

- **Login/Autenticação** - verificar se as credenciais a serem inseridas se tem acesso à aplicação.
- **Expiração de JWT** - definir um tempo limite para o token de acesso, isto faz quando o token expira não seja mais aceite pelo servidor para processar solicitações, forçando o utilizador a autenticar-se novamente ou a utilizar um mecanismo de atualização, para o utilizador não estar sempre a autenticar-se.
- **Injeção de código** - testar a vulnerabilidade do código para prevenir a inserção de dados maliciosos.
- **Exposição de dados sensíveis** - garantir que os dados com informação sensíveis estão devidamente protegidos.
- **Operações de sistemas de ficheiros** - validar o acesso aos dados pretendidos, tanto dentro como fora da organização.
- **Validação de input** - testar as vulnerabilidades sobre ataques de injeção SQL, API e scripts.

Estratégia

A estratégia será baseada em testes de análise de código e ferramentas de teste, focado em:

- **SAST (Static Application Security Testing)** - Análise automática do código-fonte. Uso de ferramentas, como por exemplo, SonarQube, Snyk Code e Semgrep.
- **DAST (Dynamic Application Security Testing)** - Testes em tempo de execução. Uso de ferramentas, como por exemplo, Burp Suite, Snyk Code e Nikto.

Recursos

Grupo: 2 programadores e 2 analistas de segurança.

Cronograma

O SAST, será utilizado durante toda a produção de código, para verificar e percebendo as vulnerabilidades que o código apresenta ao longo do seu desenvolvimento. O DAST, será utilizado na fase de testes, para validar a segurança do código desenvolvido.

9 Conclusão

Ao longo deste trabalho foi desenvolvido um sistema de gestão de workspaces e documentos com uma forte preocupação ao nível da segurança. Para tal, foi adotada uma abordagem estruturada que integrou a segurança em todas as fases do desenvolvimento, desde a definição de requisitos até à implementação de mecanismos de mitigação.

A utilização de metodologias como STRIDE e a modelação através de Data Flow Diagrams permitiram identificar de forma sistemática as principais ameaças ao sistema. A posterior avaliação de risco possibilitou priorizar essas ameaças com base na sua probabilidade e impacto, facilitando a tomada de decisões relativamente às medidas de segurança a implementar.

A definição de uma arquitetura segura, suportada por mecanismos como autenticação baseada em tokens, controlo de acessos, validação de entradas e logging de auditoria, contribuiu para reduzir significativamente a superfície de ataque do sistema.

Para além disso, a elaboração de abuse cases revelou-se essencial para compreender o comportamento de possíveis atacantes, permitindo antecipar cenários de exploração e reforçar os controlos de segurança.

Em suma, este projeto evidencia a importância de integrar práticas de segurança desde o início do desenvolvimento de software, demonstrando que uma abordagem preventiva é fundamental para a construção de sistemas robustos, seguros e resilientes.